

MÓDULO 3 · DOSSIER 03

Criptografía simétrica

La velocidad del cifrado simétrico solo se convierte en seguridad cuando la clave y los nonces se gestionan correctamente.

Material elaborado por el profesor Sergio Gevatschnaider

Fuente curricular verificable · SHA-256 9c0dce3bed40

Contenido

Propósito	3
Resultados de aprendizaje	3
Núcleo teórico	3
AES	3
ChaCha20	3
Gestión del secreto compartido	3
Profundización y criterio profesional	3
Caso de análisis	4
Entrega esperada	4
Riesgos y errores frecuentes	4
Actividades de dominio	4
Lista de comprobación	4
Referencias seleccionadas	4

Propósito

La velocidad del cifrado simétrico solo se convierte en seguridad cuando la clave y los nonces se gestionan correctamente.

Resultados de aprendizaje

1. explicar el modelo de secreto compartido.
2. diseñar el ciclo de vida de una clave.
3. elegir AEAD para datos voluminosos.

Núcleo teórico

La misma clave secreta cifra y descifra. Es rápida y adecuada para datos voluminosos, pero exige resolver generación, distribución, almacenamiento, rotación, revocación y destrucción de claves.

AES

AES es un cifrador por bloques de **128 bits**. Sus claves pueden medir 128, 192 o 256 bits. El tamaño de bloque no cambia con la longitud de la clave.

ChaCha20

ChaCha20 es un cifrador de flujo con clave de 256 bits. Se utiliza normalmente junto con Poly1305 como construcción AEAD.

Gestión del secreto compartido

La eficiencia simétrica no elimina el problema de claves. Deben definirse:

- generación con un CSPRNG;
- distribución por un canal o protocolo autenticado;
- almacenamiento y controles de acceso;
- separación por propósito mediante KDF;
- rotación y período criptográfico;
- revocación y destrucción verificable;
- registro de identificadores de clave sin registrar el secreto.

Profundización y criterio profesional

La criptografía simétrica domina la protección de datos por su eficiencia, pero desplaza el problema hacia la custodia del secreto. Un diseño debe definir generación con CSPRNG, distribución autenticada, almacenamiento, identificadores, separación por propósito, rotación, revocación, respaldo y destrucción.

La clave no debe reutilizarse entre construcciones con semánticas distintas. Una KDF con etiquetas de contexto permite derivar subclaves para cada dirección, función o versión. El nonce puede ser público, pero su política debe sobrevivir reinicios, concurrencia y múltiples emisores.

Control	Objetivo	Evidencia auditable
CSPRNG	Clave impredecible	API y fuente documentadas
Separación	Evitar uso cruzado	Etiquetas de KDF
Rotación	Limitar exposición	Período y versión de clave
Destrucción	Reducir recuperación	Procedimiento y alcance

Caso de análisis

Diseñe la protección de copias de seguridad con una clave maestra en un gestor, subclaves por archivo, AEAD y metadatos autenticados. Indique qué información puede permanecer pública.

Entrega esperada

Documento activos, actores, propiedad, parámetros, flujo, condición de fallo y decisión recomendada. Separe siempre la garantía criptográfica de la garantía operativa.

Riesgos y errores frecuentes

- usar una contraseña directamente como clave.
- registrar secretos o texto claro.
- reutilizar clave y nonce.

Actividades de dominio

1. ¿Qué aporta la separación por propósito?
2. ¿Por qué rotar no corrige una filtración previa?
3. ¿Qué metadatos conviene autenticar como AAD?

Lista de comprobación

- Puedo definir la propiedad y el adversario.
- Puedo explicar parámetros, límites y supuestos.
- Puedo detectar al menos tres configuraciones inseguras.
- Puedo justificar una decisión de arquitectura.
- Puedo relacionar el tema con una norma o especificación primaria.

Referencias seleccionadas

1. NIST SP 800-57 Part 1 Rev. 5 - <https://doi.org/10.6028/NIST.SP.800-57pt1r5>
2. OWASP Cryptographic Storage Cheat Sheet